Plan d’action

Client : Clinique de Frontignant

Auditeur : Lucas Beneteau

I. Plan d'action à court terme

Recommandation R01 : **Mettre en place une politique de mot de passe forte**

• Vulnérabilité corrigée : V01, V04, V06
• Ordre de priorité : Priorité 1/6
• Actions à réaliser :
  ▪ Activer la **complexité** des mots de passe.
  ▪ Définir un **une longueur minimum de 14 caractères pour les administrateurs et 8 caractères pour les utilisateurs.**
  ▪ Mettre en place le **verrouillage de compte** après échecs.
  ▪ Configurer un **âge maximal/minimal** du mot de passe.
  ▪ Forcer ensuite le **changement de tous les mots de passe**.
 	
Ressources : https://learn.microsoft.com/fr-fr/microsoft-365/admin/misc/password-policy-recommendations?view=o365-worldwide

Recommandation R02 : **Supprimer les identifiants en clair présent localement ou sur le reseau**

• Vulnérabilité corrigée : V02, V03, V10
• Ordre de priorité : Priorité 2/6
• Actions à réaliser :
  ▪ Vérifier et supprimer tout stockage de mots de passe en clair sur les **partages réseau** et le **disque local**.
  ▪ Ne pas stocker de mot de passe en clair dans la description des objets AD.

Recommandation R03 : **Arrêter la réutilisation du même compte Administrateur local**

• Vulnérabilité corrigée : V08
• Ordre de priorité : 3/6
• Actions à réaliser :
  ▪ Interdire l'usage du même compte Administrator local sur plusieurs machines.
  ▪ Déployer Microsoft LAPS pour générer des mots de passe locaux uniques et assurer leur rotation automatique.
 	
Ressources LAPS: https://learn.microsoft.com/fr-fr/windows-server/identity/laps/laps-overview

Recommandation R04 : **Restreindre et sécuriser les comptes de service**

• Vulnérabilité corrigée : V05
• Ordre de priorité : Priorité 4/6
• Actions à réaliser :
  ▪ Identifier les comptes de service exposés (avec **SPN**).
  ▪ Migrer vers des **gMSA** pour la gestion sécurisée.
  ▪ Révoquer les **SPN des comptes Admin**.
 	
Ressources gMSA: https://learn.microsoft.com/fr-fr/windows-server/identity/ad-ds/manage/group-managed-service-accounts/group-managed-service-accounts/group-managed-service-accounts-overview

Recommandation R05 : **Sécuriser les tâches planifiées**

• Vulnérabilité corrigée : V07
• Ordre de priorité : Priorité 5/6
• Actions à réaliser :
  ▪ Identifier les tâches planifiées exécutées par des **comptes privilégiés**.
  ▪ Remplacer par des **comptes gérés (gMSA)**.
  ▪ Appliquer le **principe du moindre privilège** : donner uniquement les droits nécessaires au gMSA.
 	
Ressources gMSA: https://learn.microsoft.com/fr-fr/windows-server/identity/ad-ds/manage/group-managed-service-accounts/group-managed-service-accounts/group-managed-service-accounts-overview

Recommandation R06 : **Protection contre le DUMP LSASS**

• Vulnérabilité corrigée : V09
• Ordre de priorité : Priorité 6/6
• Actions à réaliser :
  ▪ Activer **Credential Guard** et **LSA Protection** sur serveurs/postes sensibles.
  ▪ Mettre les admins dans **Protected Users** (pas de cache de mot de passe, Kerberos renforcé).
 	
Ressources :
Credential Guard:
https://learn.microsoft.com/fr-fr/windows/security/identity-protection/credential-guard/how-it-works
Protected Users:
https://www.it-connect.fr/active-directory-utilisez-le-groupe-protected-users-pour-les-admins/

II. Plan d'action à long terme

Recommandation R01 : **Surveillance de l'environnement**

• Vulnérabilité corrigée : V09
• Ordre de priorité : Priorité 1/2
• Actions à réaliser :
  ▪ Déployer un **EDR** sur tous les postes/serveurs.
  ▪ Centraliser les logs dans un **SIEM** (événements Windows, AD, Sysmon, EDR).
  ▪ Détecter activités sensibles : dump LSASS, création SPN, ajouts groupes Admin.
  ▪ Installer et configurer **Sysmon**.

Recommandation R02 : **Administration en tiers**

• Vulnérabilité corrigée : V11, V09
• Ordre de priorité : Priorité 2/2
• Actions à réaliser :
  ▪ Séparer les **tiers** :
  o Tier 0 = DC
  o Tier 1 = serveurs
  o Tier 2 = postes.
  ▪ Créer des **comptes dédiés** par tier (pas de réutilisation).
  ▪ Déployer un **bastion et un poste d'admin sécurisé (PAW)**.
  ▪ MFA obligatoire pour tout compte admin.
 	
Ressources : https://www.it-connect.fr/active-directory-tiering-model-les-fondamentaux/